

Rapport d'investigation, Sécurité

Simulation d'attaque par force brute sur Client01, détection via Wazuh (SIEM)

Antikat Olouchessi, Polytechnique Montréal, certificat en cybersécurité, Labo maison, Phase 2

1. Résumé

Pour mon labo personnel de cybersécurité, j'ai simulé volontairement une attaque par force brute sur Client01 (plusieurs tentatives de connexion avec un mauvais mot de passe), pour vérifier que le SIEM Wazuh que j'ai installé détecte bien ce genre d'activité. Résultat : Wazuh a détecté et journalisé chacune des six tentatives échouées, avec l'horodatage, la machine concernée et le code d'erreur Windows associé.

2. Informations générales

Analyste	Antikat Olouchessi
Système affecté	Client01 (Windows 11 Pro, agent Wazuh id 002)
Type d'incident	Tentatives d'authentification échouées répétées (simulation de force brute)
Date de l'incident	16 septembre 2026
Période de l'incident	de 14 h 07 min 45 s à 14 h 08 min 00 s (environ 15 secondes)
Outil de détection	Wazuh (SIEM), règle 60122 (« Logon Failure - Unknown user or bad password »)
Sévérité (Wazuh)	Niveau 5, Low, par événement individuel
Nature de l'incident	Test contrôlé et volontaire, aucune menace réelle

3. Chronologie des événements (Qui, Quoi, Quand)

J'ai fait le test directement sur Client01 : sur l'écran de connexion Windows, j'ai saisi volontairement un mauvais mot de passe à six reprises, avec quelques secondes entre chaque tentative, puis je me suis reconnectée normalement avec les bons identifiants.

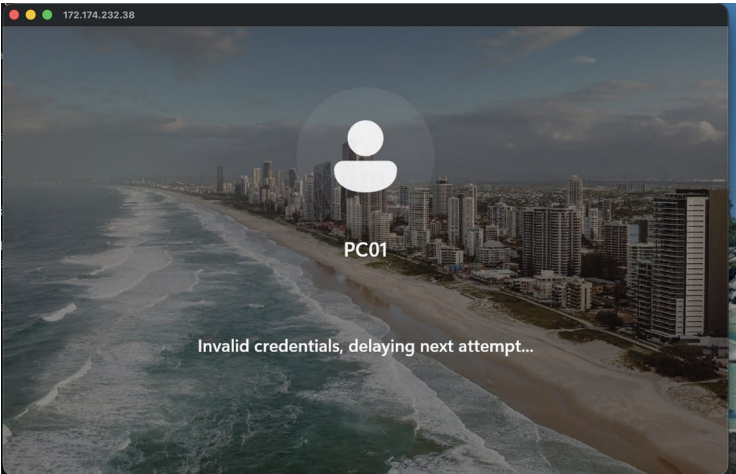


Figure 1. Écran de connexion de Client01 affichant "Invalid credentials, delaying next attempt..." après une tentative volontairement échouée.

Windows affiche ce message et impose un court délai avant la prochaine tentative, un mécanisme de protection intégré qui ralentit naturellement les attaques par force brute automatisées. J'ai laissé passer ce délai avant chaque nouvel essai.

- 14 h 07 min 45 s : 1^{re} tentative échouée
- 14 h 07 min 49 s : 2^e tentative échouée
- 14 h 07 min 52 s : 3^e tentative échouée
- 14 h 07 min 55 s : 4^e tentative échouée
- 14 h 07 min 57 s : 5^e tentative échouée
- 14 h 08 min 00 s : 6^e tentative échouée

Une septième tentative, cette fois avec le bon mot de passe, a réussi (elle n'est pas journalisée comme échec).

4. Détection (comment j'ai repéré l'incident)

J'ai repéré les six tentatives dans le tableau de bord Wazuh, module Threat Hunting, en filtrant sur l'agent Client01. La vue d'ensemble affichait 6 alertes de type « Authentication failure » sur les dernières 24 heures, sans aucune authentification réussie comptabilisée sur la même période, ce qui est cohérent avec une série de tentatives ratées suivies d'une reprise de session normale (non capturée comme échec).

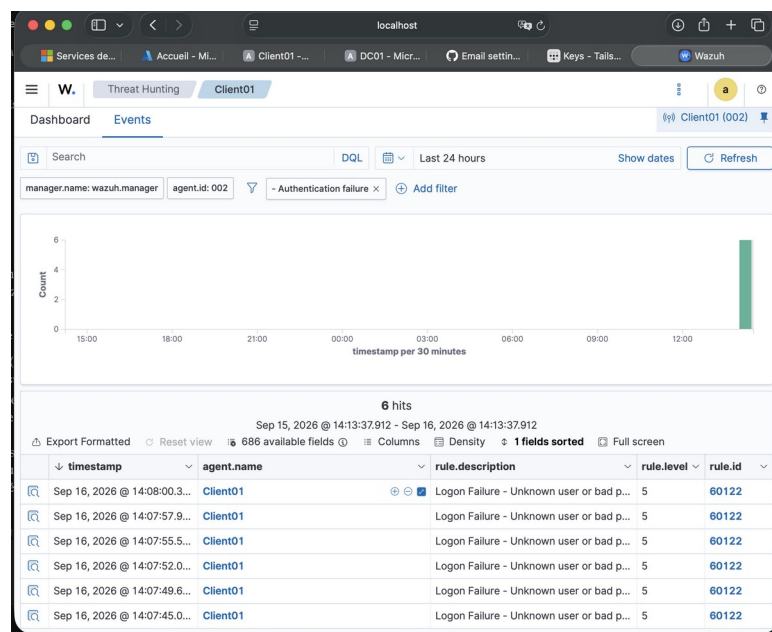


Figure 2. Liste des 6 événements « Logon Failure - Unknown user or bad password » (règle 60122, niveau 5) détectés sur Client01 entre 14 h 07 min 45 s et 14 h 08 min 00 s.

Les six lignes apparaissent regroupées sur une fenêtre de 15 secondes à peine, avec exactement le même agent et la même règle. C'est ce regroupement serré dans le temps qui rend un pattern de force brute facile à repérer visuellement, même sans outil d'analyse avancé.

5. Détails techniques de l'alerte

En ouvrant le détail d'un des six événements (Document Details), voici les champs les plus utiles pour l'investigation :

Document Details

[View surrounding documents](#)
[View single document](#)

Table

JSON

t GeoLocation.city_name	Stoney Creek
t GeoLocation.country_name	Canada
🌐 GeoLocation.location	{ "lon": -79.7139, "lat": 43.1854 }
t GeoLocation.region_name	Ontario
t _index	wazuh-alerts-4.x-2026.09.16
t agent.id	002
t agent.ip	100.118.199.86
t agent.name	Client01
t data.win.eventdata.authenticationPackageName	Negotiate
t data.win.eventdata.failureReason	%%2313
t data.win.eventdata.ipAddress	142.122.118.177
t data.win.eventdata.ipPort	0
t data.win.eventdata.keyLength	0
t data.win.eventdata.logonProcessName	User32
t data.win.eventdata.logonType	7

Figure 3. Détail complet d'un événement de connexion échouée (champs data.win.eventdata et GeoLocation).

C'est ce niveau de détail qui transforme une simple alerte en preuve exploitable : on y retrouve la machine, le type de connexion, le code d'erreur Windows exact et même une géolocalisation associée à l'adresse IP enregistrée. J'ai repris les champs les plus pertinents dans le tableau ci-dessous.

Agent concerné	Client01 (agent.id 002, adresse Tailscale 100.118.199.86)
Règle Wazuh	60122, Logon Failure - Unknown user or bad password
Niveau de sévérité	5 (Low)
Type de connexion (logonType)	7 (Unlock, déverrouillage de session)
Package d'authentification	Negotiate
Code d'échec Windows (failureReason)	%%2313 (nom d'utilisateur inconnu ou mot de passe incorrect)
Adresse IP source enregistrée	142.122.118.177
Géolocalisation associée à l'IP	Stoney Creek, Ontario, Canada

6. Analyse et évaluation du risque

Le code d'échec %%2313 confirme que ce sont bien des tentatives avec un mot de passe (ou un nom d'utilisateur) incorrect, et le type de connexion 7 (Unlock) correspond exactement à ce que j'ai fait pendant le test : déverrouiller l'écran de session avec de mauvais identifiants, à répétition.

Un point à noter pour rester rigoureuse : l'adresse IP source enregistrée par Windows (142.122.118.177, géolocalisée en Ontario) ne correspond pas forcément à l'origine réelle de la tentative dans ce contexte-là. Client01 étant une VM Azure accédée à distance, l'adresse capturée peut refléter un relais réseau (Azure, RDP) plutôt qu'une machine attaquante distincte. Dans une vraie investigation, je corroborerais cette adresse avec les journaux réseau (pare-feu, VPN, fournisseur cloud) avant de conclure à une origine géographique précise, une IP seule n'est jamais une preuve suffisante.

Autre constat intéressant : les six événements ont chacun été journalisés au niveau 5 (Low), et aucune alerte de niveau 12 ou plus (qui indiquerait normalement une règle de corrélation déclenchée par un volume anormal d'échecs en peu de temps) ne s'est déclenchée pendant le test. Ça montre que la configuration par défaut de Wazuh, dans mon déploiement, n'a pas encore de règle de fréquence dédiée aux échecs de connexion répétés sur une courte période, une amélioration à prévoir (voir mes recommandations).

7. Recommandations

- Activer ou configurer une règle de corrélation Wazuh (frequency rule) qui élève automatiquement la sévérité quand plusieurs échecs d'authentification arrivent sur le même compte ou la même machine en peu de temps, plutôt que de ne journaliser que des événements individuels de faible niveau.
- Ajouter une stratégie de verrouillage de compte (Account Lockout Policy) via GPO sur le domaine, en plus des GPO déjà en place (complexité des mots de passe, verrouillage de session, restriction USB). Un verrouillage automatique après un certain nombre d'échecs limiterait concrètement les attaques par force brute, en plus de la détection.
- Changer le mot de passe par défaut du tableau de bord Wazuh (admin / SecretPassword), pour que l'outil de surveillance lui-même ne devienne pas un point faible.
- Dans un contexte réel, valider toute adresse IP suspecte avec les journaux réseau avant de lui attribuer une origine géographique.

8. Conclusion

Ce test contrôlé confirme que mon environnement de surveillance Wazuh détecte correctement les tentatives de connexion échouées sur les postes surveillés (Client01), avec l'horodatage précis et les détails techniques nécessaires à une investigation. L'exercice m'a aussi permis de repérer une limite concrète de ma configuration actuelle (l'absence de règle de corrélation pour les échecs répétés), une piste d'amélioration réaliste pour la suite du labo.